

SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE CODE: CSA51

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 40%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

CONSTRAINT-BASED PROBLEM SOLVING

Code of Conduct:

I _____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Annexure A

CONSTRAINT-BASED PROBLEM SOLVING

1. A financial institution must secure all web transactions using TLS, but legacy systems only support older SSL versions. Design a solution to ensure secure communication.

Constraints:

- A. Backward compatibility must be maintained for 20% legacy clients
 - B. Sensitive data must not be transmitted using SSL
 - C. System downtime must be minimal during migration
 - D. Cost of implementation should be optimized
-
2. An e-commerce platform is considering implementing the SET protocol for payment security but currently uses TLS-based encryption. Analyze and propose a decision.

Constraints:

- A. Must support high transaction throughput (10,000 transactions/minute)
- B. Compatibility with modern browsers is required
- C. Implementation complexity should be minimized
- D. Regulatory compliance (PCI-DSS) must be ensured

3. A corporate network is experiencing repeated malware infections that spread rapidly without user interaction. Propose a containment and prevention strategy.

Constraints:

- A. The network consists of 500+ interconnected systems

- B. Downtime per system should not exceed 10 minutes
- C. Detection must occur within 2 minutes of infection
- D. Solution must differentiate between virus, worm, and Trojan behavior

4. An organization needs to deploy a firewall architecture to protect its internal network from external threats and insider attacks. Design the solution.

Constraints:

- A. Must support both packet filtering and application-level inspection
- B. Latency introduced should not exceed 5 ms per request
- C. Should handle at least 1 Gbps traffic
- D. Must allow secure remote access for employees

5. A large enterprise network generates excessive false positives in its IDS, leading to alert fatigue. Propose an optimized IDS/IPS solution.

Constraints:

- A. Detection accuracy must be at least 95%
- B. False positive rate should be reduced below 5%
- C. System must process real-time traffic of 2 Gbps
- D. Solution should integrate with existing firewall infrastructure

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Problem Understanding	25%	Clearly defines the problem and identifies all relevant constraints accurately	Identifies most constraints with minor gaps	Partial understanding; misses key constraints	Fails to identify constraints correctly

Constraint Analysis	25%	Analyzes constraints effectively and prioritizes them logically	Provides reasonable analysis with some prioritization	Limited analysis; weak prioritization	No meaningful analysis or prioritization
Solution Development	25%	Develops optimal and feasible solutions satisfying all constraints	Develops workable solutions with minor limitations	Solutions partially satisfy constraints	Solutions do not meet constraints
Application of Concepts	15%	Effectively applies appropriate concepts, methods, or tools	Applies concepts with minor errors	Limited application; requires guidance	Unable to apply relevant concepts
Justification	10%	Provides strong justification for decisions with logical reasoning	Provides justification with some clarity	Weak or unclear justification	No justification provided

CONSTRAINT-BASED PROBLEM SOLVING – QUESTION 3

Title

Containment and Prevention Strategy for Rapidly Spreading Malware in a Corporate Network

1. Problem Statement

A corporate network consisting of more than **500 interconnected systems** is experiencing repeated malware infections that spread rapidly without user interaction. Such behavior strongly indicates the possibility of **network-propagating malware, particularly worms**, although viruses and Trojans may also be present in the environment.

The organization requires a security strategy that can:

- Detect infections within **2 minutes**.
- Contain infected systems quickly.
- Keep downtime for each system below **10 minutes**.
- Distinguish between **viruses, worms, and Trojans**.
- Protect more than **500 interconnected systems**.
- Prevent repeated malware outbreaks.

The proposed solution combines **endpoint protection, network segmentation, IDS/IPS, centralized monitoring, firewall controls, automated isolation, patch management, and incident-response procedures**.

2. Understanding the Malware Types

Before designing the solution, the behavior of different malware types must be understood.

2.1 Virus

A **virus** is malware that attaches itself to a legitimate file or program and generally requires execution of the infected host file to propagate.

Typical characteristics:

- Attaches to files.
- Replicates when an infected file is executed.
- May modify or corrupt files.
- Can spread through shared files or removable media.

Example Behavior

Infected File

|
v

User Executes File

|
v

Malware Activates

|
v

Other Files Infected

2.2 Worm

A **worm** is malware capable of self-propagating across networks without requiring the user to execute an infected file on every target.

Typical characteristics:

- Automatic network propagation.
- Scans for vulnerable systems.
- Exploits security weaknesses.
- Generates large volumes of network traffic.
- Can infect many systems rapidly.

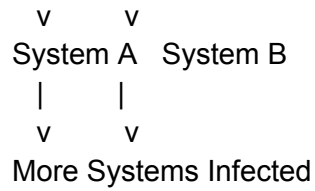
Example Behavior

Compromised System

|
v

Network Scanning

|
+----+----+
| |



The description in the case study — **rapid spread without user interaction** — makes worm-like behavior an important detection priority.

2.3 Trojan

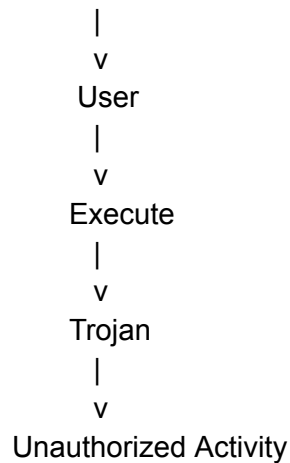
A **Trojan** is malicious software that disguises itself as legitimate software or content.

Typical characteristics:

- Appears legitimate to the user.
- Does not primarily self-replicate like a worm.
- Can establish unauthorized access.
- May download additional malware.
- Can communicate with attacker-controlled infrastructure.

Example

Legitimate-Looking Program



3. Constraint Analysis

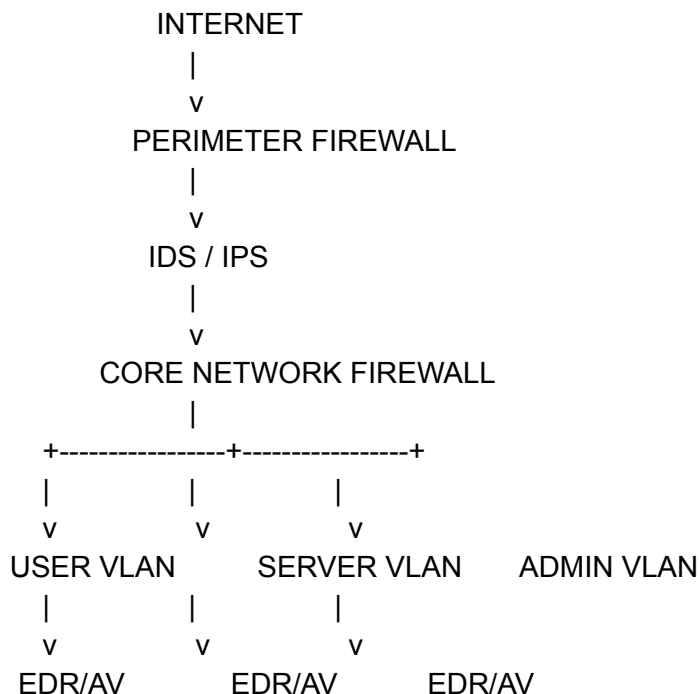
The proposed security solution must satisfy all four constraints.

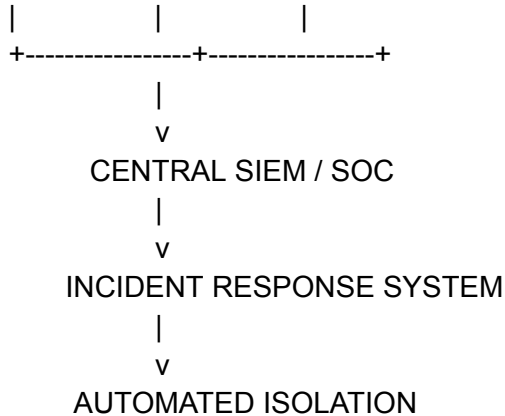
Constraint	Requirement	Proposed Approach
Network size	500+ systems	Centralized security management
Maximum downtime	≤ 10 minutes/system	Automated endpoint isolation and rapid recovery
Detection time	≤ 2 minutes	Real-time EDR + IDS/IPS + centralized SIEM
Malware differentiation	Virus, worm, Trojan	Behavior-based detection and network telemetry

The **2-minute detection requirement** is the most time-sensitive constraint and should therefore receive the highest priority.

4. Proposed Security Architecture

The recommended architecture uses multiple security layers.





This layered architecture prevents a single security control from becoming the only defense mechanism.

5. Detection Strategy

To meet the **2-minute detection requirement**, the organization should use continuous monitoring.

5.1 Endpoint Detection and Response

An **Endpoint Detection and Response (EDR)** platform should be deployed on corporate systems.

EDR can monitor:

- Running processes.
- File modifications.
- Network connections.
- Suspicious process behavior.
- Privilege changes.
- Malware indicators.
- Repeated failed actions.

When suspicious behavior is detected, the endpoint can automatically be isolated from the network.

5.2 IDS/IPS

A network IDS/IPS should inspect network traffic for suspicious patterns.

The IDS/IPS can detect:

- Port scanning.
- Abnormal connection rates.
- Exploit attempts.
- Suspicious protocols.
- Known malicious signatures.
- Unusual lateral movement.

Detection Flow

Network Traffic

|

v

IDS/IPS

|

v

Analyze Traffic

|

+-----+

| |

Normal Suspicious

| |

v v

Allow Alert/Block

|

v

SIEM

5.3 Centralized SIEM

A **Security Information and Event Management (SIEM)** system should collect security events from:

- EDR agents.
- IDS/IPS.
- Firewalls.

- Servers.
- Authentication systems.
- DNS infrastructure.
- Network devices.

The SIEM correlates events to identify coordinated attacks.

For example:

Host A → Port Scan

Host A → Multiple Failed Connections

Host A → Suspicious Process

Host A → Unusual Outbound Traffic

Individually, these events may appear less significant.

Together, they can indicate a malware infection.

6. Malware Classification Strategy

The system should classify malware based on its observed behavior.

Virus Detection

Indicators:

- Modification of executable files.
- Unexpected file replication.
- Changes to legitimate files.
- Antivirus signature matches.

File Modification

+

Executable Infection

+

Replication

↓

Likely Virus

Worm Detection

Indicators:

- Rapid network scanning.
- Large numbers of connection attempts.
- Attempts to exploit multiple systems.
- Similar infection behavior across hosts.
- Rapid lateral movement.

Rapid Scanning

+

Self-Propagation

+

Multiple Hosts

↓

Likely Worm

Trojan Detection

Indicators:

- Suspicious legitimate-looking application.
- Unexpected outbound connections.
- Unauthorized process behavior.
- Communication with suspicious external infrastructure.
- Unexpected persistence mechanisms.

Legitimate-Looking Program

+

Suspicious Activity

+

Unauthorized Communication

↓

Likely Trojan

7. Automated Containment Strategy

Once an infection is detected, the infected machine should be automatically isolated.

Malware Detected

|

v

Generate Alert

|

v

Confirm Suspicious Behavior

|

v

Isolate Endpoint

|

v

Block Malicious Communication

|

v

Investigate

|

v

Clean / Reimage

|

v

Patch and Update

|

v

Security Verification

|

v

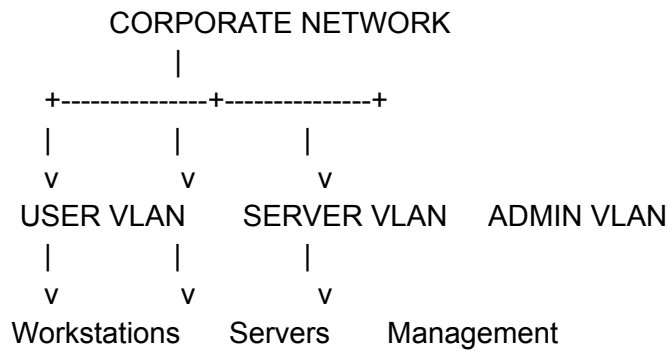
Reconnect System

Isolation should occur automatically when confidence is sufficiently high to avoid waiting for manual intervention.

8. Network Segmentation

The network should be divided into security zones.

Example:



Sensitive systems should not communicate freely with every workstation.

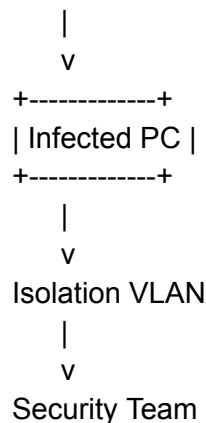
Firewall rules should implement **least-privilege communication** between network segments.

This reduces the ability of a worm to spread laterally across all 500+ systems.

9. Endpoint Isolation

When a system is identified as infected:

Normal Network



The system should retain only the minimum network connectivity needed for:

- Security investigation.
- EDR communication.
- Malware removal.
- Required administrative recovery.

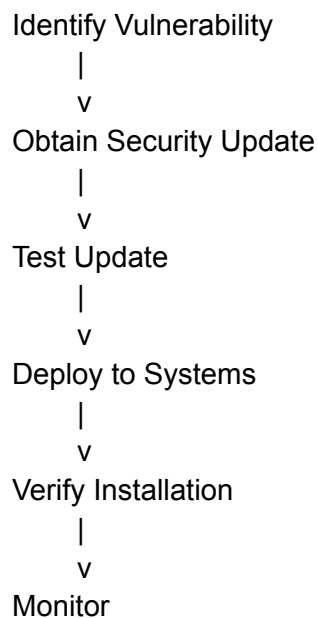
This prevents the infected endpoint from continuing to spread malware.

10. Patch Management

Worms frequently exploit vulnerable software and systems.

Therefore, the organization should implement centralized patch management.

Patch Lifecycle



Critical security patches should receive priority.

A vulnerability-management system should continuously identify missing security updates.

11. Antivirus and EDR

Traditional antivirus provides signature-based detection, while modern endpoint security can additionally use behavioral analysis.

A layered endpoint strategy should include:

Antivirus
+
Behavior Monitoring
+
EDR
+
Application Control
+
Endpoint Firewall

This improves detection against both known and previously unseen malicious behavior.

12. Firewall Controls

Internal firewall policies should restrict unnecessary communication.

For example:

User VLAN → Server VLAN
|
+--> Only required services

Unnecessary inbound and lateral connections should be blocked.

The perimeter firewall should also restrict suspicious outbound communication.

13. Email Security

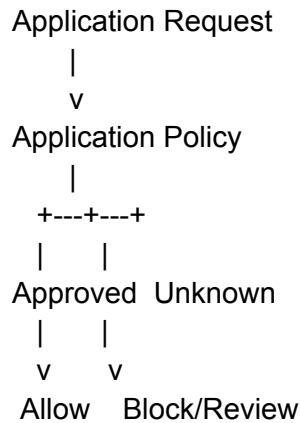
Since malware can enter through email, the organization should deploy:

- Attachment scanning.
- Malicious URL detection.
- Sender authentication controls.
- File-type restrictions.
- Sandboxing where appropriate.
- Phishing detection.

This reduces the chance of malware entering the corporate network through email.

14. Application Control

Only approved applications should be permitted where practical.

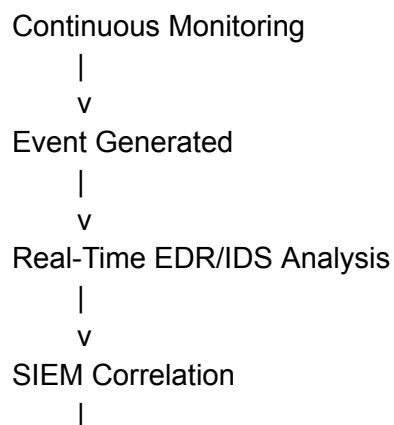


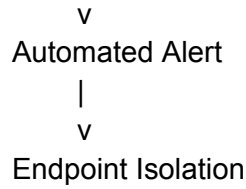
This is particularly useful against Trojans disguised as legitimate software.

15. Detection Within Two Minutes

The organization requires detection within **2 minutes**.

A suitable operational target is:





The organization should validate the actual two-minute target through controlled testing rather than assuming that deployment alone guarantees it.

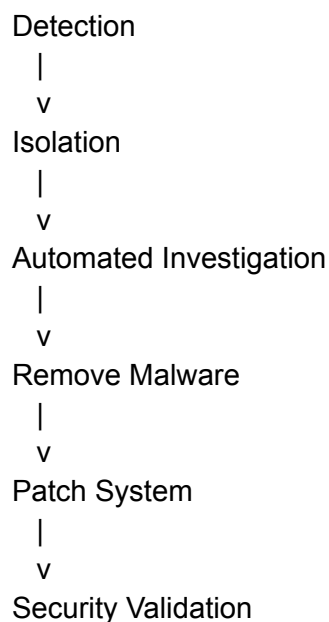
16. Downtime Requirement

Each system must have downtime of **no more than 10 minutes**.

To meet this requirement:

1. Automate endpoint isolation.
2. Maintain standardized endpoint images.
3. Keep backup configurations.
4. Use centralized patch management.
5. Automate malware removal where safe.
6. Maintain spare systems for critical users.
7. Predefine incident-response procedures.

Recovery Process



|
v
Reconnect

The actual recovery time should be measured during testing to verify compliance with the 10-minute requirement.

17. Prevention Strategy

The following controls should be implemented permanently:

Technical Controls

- EDR on endpoints.
- Network IDS/IPS.
- Next-generation firewall.
- Network segmentation.
- Endpoint firewall.
- Application control.
- Email security.
- DNS security.
- Vulnerability scanning.
- Automated patch management.
- Centralized SIEM.

Administrative Controls

- Security policies.
 - Incident-response procedures.
 - Regular security training.
 - Least-privilege access.
 - Strong authentication.
 - Periodic security audits.
-

18. Incident Response Plan

The incident-response process should follow:

1. Detection
- ↓
2. Identification
- ↓
3. Containment
- ↓
4. Eradication
- ↓
5. Recovery
- ↓
6. Monitoring
- ↓
7. Lessons Learned

Detection

Identify suspicious activity through EDR, IDS/IPS, and SIEM.

Identification

Determine whether the event is a virus, worm, Trojan, or another threat.

Containment

Isolate affected systems and block malicious communication.

Eradication

Remove malware and eliminate the vulnerability that enabled the infection.

Recovery

Restore the system to a trusted state and reconnect it after verification.

Lessons Learned

Analyze the incident and improve security controls.

19. Constraint Satisfaction

Constraint	Proposed Solution	Expected Compliance
500+ systems	Centralized EDR, SIEM and network security	Scalable
≤ 10 min downtime/system	Automated isolation and standardized recovery	Designed to meet target
Detection ≤ 2 min	Continuous EDR + IDS/IPS + SIEM correlation	Designed to meet target
Differentiate malware	Behavioral and network indicators	Virus/Worm/Trojan classification
Prevent recurrence	Patching + segmentation + application control	Continuous protection

20. Example Attack Scenario

Consider a worm infecting one workstation.

Stage 1 – Initial Infection

Workstation A

|
v

Worm Activated

Stage 2 – Network Scanning

Workstation A

|
+--> Scan B
+--> Scan C
+--> Scan D
+--> Scan E

The IDS/IPS detects abnormal scanning.

Stage 3 – EDR Detection

The endpoint detects suspicious processes and network behavior.

Stage 4 – SIEM Correlation

EDR Alert
+
Network Scan
+
Abnormal Connections
↓
High-Confidence Malware Alert

Stage 5 – Automatic Isolation

Workstation A
|
v
Isolation VLAN

Stage 6 – Investigation and Recovery

Security personnel investigate the system, remove the malware, apply required patches, validate the endpoint, and reconnect it.

This prevents the infection from spreading throughout the corporate network.

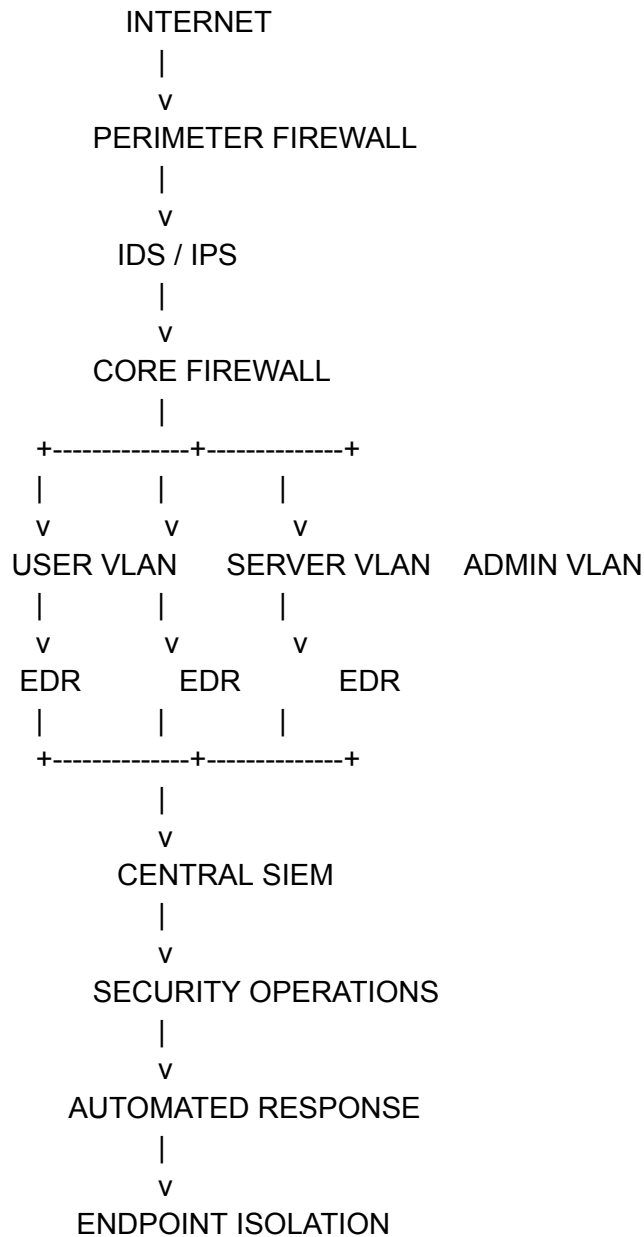
21. Security Benefits

The proposed architecture provides:

- Rapid malware detection.
- Automated containment.
- Reduced lateral movement.
- Protection against network worms.
- Better detection of Trojans.
- Detection of file-infecting viruses.
- Reduced attack surface.
- Centralized visibility.

- Faster incident response.
 - Improved system recovery.
-

22. Final Recommended Architecture



23. Final Recommendation

The organization should implement a **layered malware defense strategy** rather than depending on a single antivirus solution.

The recommended solution is:

EDR + IDS/IPS + SIEM + Network Segmentation + Firewall + Automated Isolation + Patch Management + Application Control + Email Security

The most important operational requirement is to configure automated detection and containment so that suspicious systems can be isolated rapidly while minimizing disruption to legitimate systems.

24. Conclusion

The corporate network's rapid, user-independent malware propagation indicates a significant risk of **worm-like network behavior**, although viruses and Trojans must also be considered during investigation.

A layered security architecture combining **EDR, IDS/IPS, SIEM, firewalls, network segmentation, patch management, application control, and automated endpoint isolation** provides an effective strategy for preventing and containing malware.

The proposed design addresses the stated constraints by supporting more than **500 systems**, targeting detection within **2 minutes**, minimizing endpoint downtime toward the required **10-minute limit**, and distinguishing virus, worm, and Trojan behavior through file, endpoint, and network indicators.

The solution also follows a continuous security lifecycle:

Detect → Identify → Contain → Eradicate → Recover → Monitor → Improve

This approach reduces malware propagation, limits lateral movement, improves incident-response speed, and strengthens the overall security posture of the corporate network.